

SoulBound Token 복구 메커니즘과 고객 중심 가디언 시스템의 적용*

김 재 현,^{1*} 김 나 연,¹ 이 용 학,² 양 성 민,² 김 성 환^{3*}
^{1,2,3}건국대학교 (학생, 대학원생, 교수)

SoulBound Token Recovery Mechanism and the Application of a Customer-Centric Guardian System*

Jae-Hyun Kim,^{1*} Na-Yeon Kim,¹ Yong-Hak Lee,² Seong-Min Yang,² Sung-Hwan Kim^{3*}
^{1,2,3}Konkuk University (Undergraduate Student, Graduate Student, Professor)

요 약

데이터를 중앙 서버에 저장하는 방식에 많은 문제점이 대두되면서 분산화된 저장 서버에 대한 관심이 높아지고 있다. 일례로 SoulBound Token을 활용한 개인 정보 저장 방식이 제안되었으나, 토큰을 분실하거나 재생성을 해야 하는 경우에 대한 적합한 해결책이 부족한 상태이다. 기존의 “가디언” 개념은 공인된 공공기관을 가디언으로 설정하여 신분을 증명하는 방식이지만, 이는 블록체인의 탈중앙화 개념과 상충되며, 스타트업이 가디언 방식을 적용하려는 경우 공공기관의 연계가 부담스러운 상황이다. 본 논문은 이러한 문제점을 해결하기 위하여 스타트업의 고객들이 서로의 가디언이 되어 공공기관의 의존성을 줄이면서도 해킹의 위험을 최소화할 수 있는 “고객 중심 가디언” 개념을 제안한다. 이를 통하여 스타트업이 SBT를 활용한 분산 정보 시스템을 활용하여 시스템의 보안성을 강화하고, 탈중앙화된 정보 저장 및 관리 방식을 안전하게 구현 가능한 것을 확인하였다.

ABSTRACT

As issues with storing data on centralized servers continue to emerge, interest in decentralized storage systems is growing. For instance, a method utilizing SoulBound Token for personal information storage has been proposed; however, suitable solutions for cases involving token loss or regeneration remain insufficient. The existing “guardian” concept designates authorized public institutions as guardians to verify identity, but this approach conflicts with the decentralized nature of blockchain. Additionally, it poses a burden for startups attempting to implement guardian systems due to the need to coordinate with public institutions. This paper addresses these issues by proposing a “Customer-Centric Guardian” system, where customers of a startup act as guardians for one another, thereby reducing reliance on public institutions while minimizing the risk of hacking. Through this approach, startups can enhance the security of their systems using SBT and implement decentralized data storage and management systems in a secure manner.

Keywords: Blockchain, Smart Contracts, SoulBound Token, Guardian System

Received(11. 27. 2024), Modified(1st: 01. 20. 2025,
2nd: 02. 14. 2025), Accepted(02. 20. 2025)

* 이 논문은 2024년도 건국대학교 우수연구인력 양성사업 지원
과 정부(과학기술정보통신부)의 재원으로 한국연구재단의 지원

을 받아 수행된 연구임(RS-2023-00240936).

† 주저자, passiontom@naver.com

‡ 교신저자, shkim1213@konkuk.ac.kr(Corresponding author)

I. 서 론

현재 중앙화된 데이터 저장 방식에는 많은 보안 문제가 야기되고 있다. 대표적으로 2017년 발생한 페이스북 데이터 유출 사건은 중앙화된 데이터베이스의 보안 취약성으로 인해 수억 명의 사용자 데이터와 비밀번호가 암호화되지 않은 상태로 노출되었다. 이와 같은 사건은 중앙화된 시스템이 해킹 및 보안 사고에 취약하다는 것을 보여준다.

이에 대한 대안으로 탈중앙화 저장 방식이 주목받고 있으며, 특히 블록체인 기술의 발전과 함께 데이터를 탈중앙화 방식으로 저장한 후 Soulbound Token을[1] 활용한 데이터 분산 저장 방식이 연구되고 있다[2]. 그러나 SBT를 분실하거나 재생성해야 하는 경우 적절한 복구 메커니즘이 필요한 상황이다.

이러한 문제를 해결하기 위하여 본 논문에서는 기존의 공공기관 의존 가디언 시스템을 대체할 수 있는 "고객 중심 가디언" 시스템을 제안한다. 이 시스템은 스타트업의 고객들이 서로의 가디언이 되어 서로의 신분을 증명해주는 방식으로 작동한다. 이를 통해 스타트업이 추가적인 비용 부담 없이 SBT를 활용한 분산 정보 시스템을 효과적으로 운영할 수 있을 것으로 기대한다. 이와 관련한 코드는 링크[3]에서 확인 가능하다.

II. 배경 지식

2.1 SoulBound Token

SBT는 이더리움[4] 기반의 Non-Fungible Token과 유사하지만, 타인에게 양도가 불가능한 특성을 가지고 있다. 이러한 특성으로 인하여 개인의 신분을 증명하는 방법 및 개인의 민감한 개인 정보를 저장하는 방식으로 많이 사용되고 있다. SBT는 한번 발행되면 수정할 수 없으며, 불변성의 원칙을 따른다. 이를 통해 토큰의 신뢰성을 보장하고 위조나 변조를 방지할 수 있다. SBT는 다른 지갑으로 이전할 수 없는 비이전성의 특성을 가지며, 이러한 특성으로 인하여 소유자의 신원을 영구적으로 보증할 수 있다. 모든 SBT의 데이터는 블록체인에 기록되므로 누구나 투명하게 검증할 수 있어 신뢰성과 검증 가능성을 높인다.

SBT 생성은 Fig. 1과 같은 방식으로 진행된다. 우선 데이터를 InterPlanetary File System[5]에 저장하여 중앙 서버 의존성을 낮추고 파일을 분산화하여 저장하기 때문에 해킹의 위험성을 줄인다.

IPFS는 콘텐츠 주소 지정 방식으로 데이터를 저장하며, 데이터의 고유한 Content Identifier를 생성한다. 사용자는 생성된 CID를 기반으로 SBT를 발행한다. 이때 CID는 토큰 소유자가 해당 데이터에 접근할 수 있는 열쇠의 역할을 한다. 발행된 SBT는 설정된 특정 지갑 주소에 할당된다. SBT는 양도가

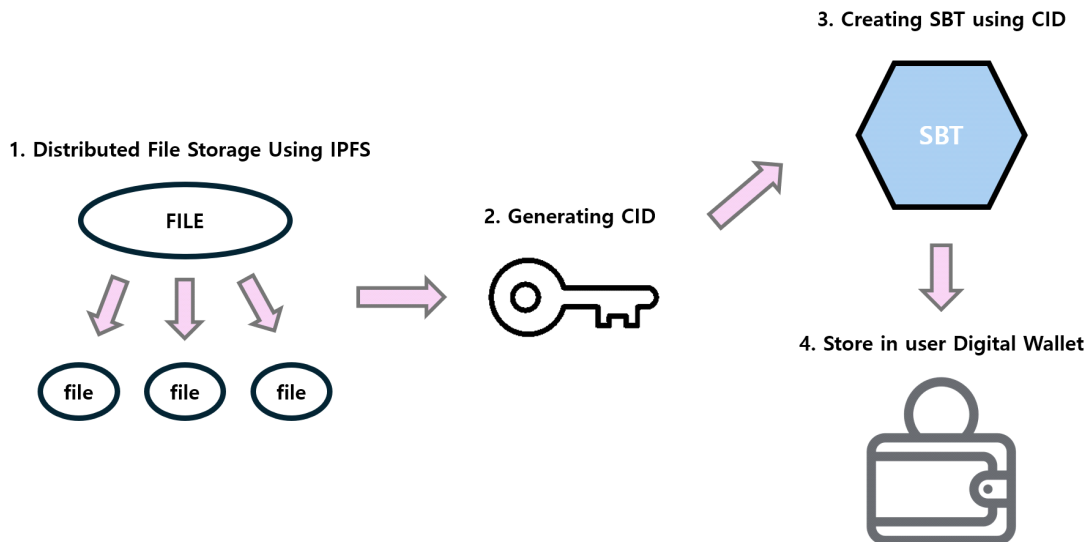


Fig. 1. The process of SBT creation

불가능한 특성을 가지고 있기 때문에 해당 지갑 주소에 영구적으로 묶이게 된다.

2.2 가디언 시스템

2.2.1 가디언 시스템 정의

가디언 시스템은[6] 블록체인 기술에서 사용자의 신원 확인 및 데이터 복구를 위한 보호자 역할을 하는 시스템이다. 가디언은 사용자가 신뢰할 수 있는 개인이나 기관이 될 수 있으며, 이들이 사용자의 데이터를 안전하게 관리 및 복구하는데 도움을 준다. 사용자가 SBT를 복구하고 싶은 경우, 가디언에게 본인 확인을 요청하고, 과반수 이상의 가디언이 찬성할 경우 SBT를 복구할 수 있으며 Fig. 2에 정리하였다.

블록체인 기술은 특성상 데이터가 한 번 소실되면 복구하기 어려운 경우가 많은데, 가디언 시스템은 이러한 데이터를 복구하는 역할을 한다. 또 가디언은 사용자의 신원을 인증하는 데 중요한 역할을 하는데, 특히나 SBT와 같은 비이전성 토큰에서 중요한 부분이다. 그 외에도 해킹이나 데이터 손실 등으로부터 사용자를 보호하는데 중요한 역할을 한다.

2.2.2 가디언 시스템 구성요소

가디언 시스템은 3가지 구성요소로 구성되어 있다. 첫 번째는 다중서명[7]으로 하나의 거래 또는 데이터 액세스를 여러 개의 개인 키가 승인하도록 요구하는 기술이다. 이는 단일 개인 키의 유출이나 분실로 인한 위험을 줄이며 여러 사람이 공동으로 관리함으로써 신뢰성을 높인다는 장점이 있다. 두 번째는 합의 알고리즘으로 블록체인 네트워크 내에서 모든 참여자가 동일한 데이터 상태를 유지하고, 변경 사항을 검증하는 방식이다. 세 번째는 보안 프로토콜이며, 데이터를 전송할 때 기밀성, 무결성, 인증을 보장하는 통신 규칙이다. 가디언 시스템에서는 주로 인터넷 상의 데이터 암호화 및 전송 보안을 보장하는 TLS 방식과[8] 네트워크 계층에서 보안성을 제공하여 데이터의 기밀성과 보안성을 유지하는 IPsec 방식을[9] 주로 사용한다. 내용은 Fig. 3에 정리하였다.

2.2.3 가디언 시스템 장점

가디언 승인은 여러 명의 가디언이 승인 절차에 참여함으로써 단일 장애점(SPOF, Single Point of Failure)을[10] 제거하고, 해킹을 성공하려면 한번에 여러 가디언의 키를 획득해야 하므로 보안성이 높아진다. 또한 사용자의 신원을 다중으로 인증할

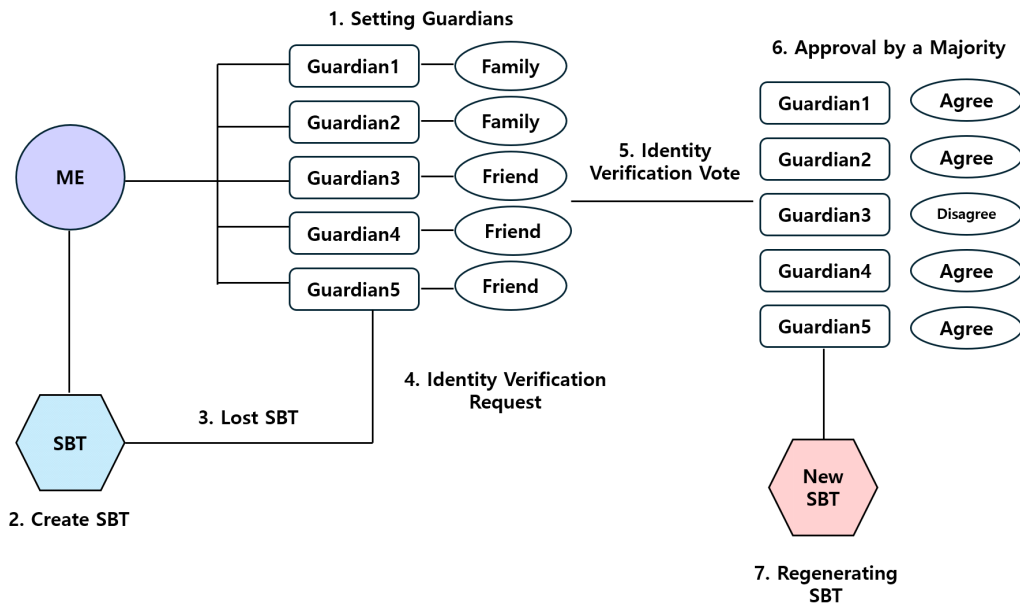


Fig. 2. Guardian system using friends

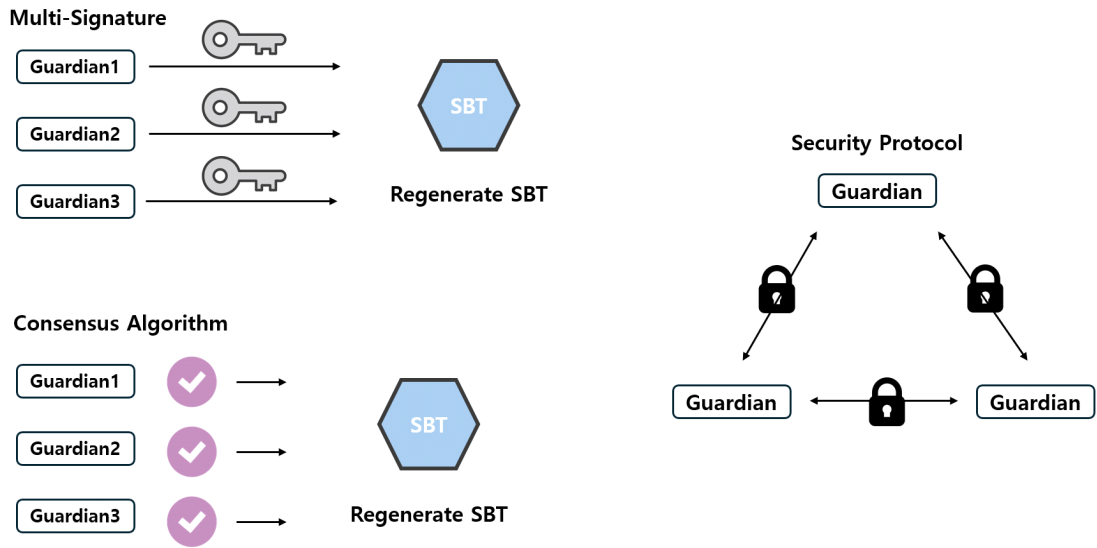


Fig. 3. Components of the Guardian System

수 있어 신뢰성이 높아지며 사용자가 접근 불가능한 상황일 때, 가디언의 승인을 통해 복구가 가능하다는 장점이 있다.

2.2.4 가디언 승인 대행

가디언 승인 대행은 사용자가 신원 확인이나 데이터 복구가 필요할 때, 지정된 가디언이 이를 대행하여 승인을 처리하는 시스템을 의미한다. 가디언 승인 대행을 통하여 긴급 상황에서 가디언 승인 대행을 통해 빠른 대응이 가능하며, 사용자의 데이터 접근을 신속하게 복구할 수 있다.

III. 관련 연구

3.1 SBT 생성

Huh et al. [11]은 2017년에 블록체인 기술을 활용하여 IoT 장치 관리에 대한 연구를 수행하였다. 이 연구는 블록체인의 탈중앙화 특성을 활용하여 IoT 장치의 관리와 구성 작업을 더 안전하고 효율적으로 수행할 수 있음을 입증하였다. 특히 RSA 공개 키 암호화 시스템을 이용해 키 관리 문제를 해결하였으며, 이를 통해 분산 환경에서도 높은 보안성을 제공할 수 있음을 보여주었다. 그러나 이 연구는 여전히 중앙화된 관리 시스템에 의존하는 방식이었고, 완전한 탈중앙화 시스템에 대한 논의는 부족하였다.

Minoli et al. [12]는 2018년에 블록체인이 IoT 보안에 어떻게 적용될 수 있는지를 처음으로 시연하였다. 이 연구는 IoT 운영 시 발생하는 보안 취약성을 강조하며, 이를 해결하기 위해 블록체인이 중요한 역할을 할 수 있음을 제시하였다. 특히, 중요한 비즈니스 요구 사항을 위해 중단 간 안전 지원의 필요성을 강조하며, 다양한 보안 기술과 전략을 적용하는 방안을 논의하였지만, 이는 주로 중앙화된 신뢰 기관을 통한 보안 관리를 가정하고 있어, 블록체인의 탈중앙화 특성을 충분히 활용하지 못했다.

DSBT 메커니즘에 대한 연구[13]는 Decentralized Soulbound Token (DSBT)을 도입하여, 기존 SBT가 가진 한계를 보완하는 방법을 제안하였다. 이 연구는 분산 신원(Decentralized Identifier)과 결합된 DSBT가 신원 인증과 개인정보 보호를 더욱 강화할 수 있음을 보여주었다. 특히, 컨소시엄 블록체인을 활용하여 기업 간 협력을 위한 신뢰 기반 시스템을 구축하는 데 초점을 맞추고 있었지만, 여전히 컨소시엄의 중앙화된 요소가 존재한다는 점에서 완전한 탈중앙화를 구현하는 데는 한계가 있었다.

Vitalik Buterin의 연구[14]는 SBT의 개념을 바탕으로 Decentralized Society(DeSoc)의 구축 가능성을 제안하였다. 이 연구는 SBT가 전송 불가능한 토큰으로서 신뢰 네트워크를 형성하고, 이를 통해 사회적 관계와 협력 메커니즘을 강화할 수 있는 이론적 틀을 제공한다. Buterin의 연구는 탈중앙화 사회에서 신뢰 기반의 협력 메커니즘을 구축하는 데

중요한 기여를 하며, 이는 고객 중심 가디언 시스템에도 적용될 수 있는 개념적 근거를 제공한다.

기존 연구들이 주로 공공기관이나 컨소시엄을 통한 중앙화된 신뢰 구조에 의존한 반면, 본 연구는 고객 간의 상호 신뢰 네트워크를 바탕으로 한 고객 중심 가디언 시스템을 통해 완전한 탈중앙화를 실현하고자 한다. 이는 비용 절감, 확장성, 빠른 복구 시간 등을 제공하며, 특히 스타트업 환경에서 높은 실용성을 가진다. 기존 연구와의 차별점은 공공기관 의존도를 줄이고, 고객 간의 신뢰를 기반으로 하는 자율적 보안 시스템을 구축했다는 점에 있다.

IV. 제안구도

4.1 고객 중심 가디언 정의

현재 스타트업 등에서 사용되는 가디언 시스템은 신뢰할 만한 가디언으로 공공기관을 많이 설정하고 있다. 따라서 사용자가 SBT를 분실하여 가디언 승인을 요청할 경우 공공기관을 포함한 과반수 이상의 가디언의 승인이 필요한 상황이다. Fig. 4와 같은 이러한 방식은 공신력 있는 공공기관이 신뢰성을 높여준다는 장점이 있지만, 특정 기관에 의존하지 않는 탈중앙화 개념에 맞지 않으며 공공기관과 연계를 해야 한다는 점이 스타트업에게 시간적, 금전적인 면에서 부담으로 작용할 수 있다. 이러한 문제를 해결하기 위하여 고객들이 서로의 가디언이 되어주는 “고객 중심 가디언” 방식을 제안하고자 한다. 현재 일부 스타트업에서 SBT를 활용한 데이터 저장 시스템을 구

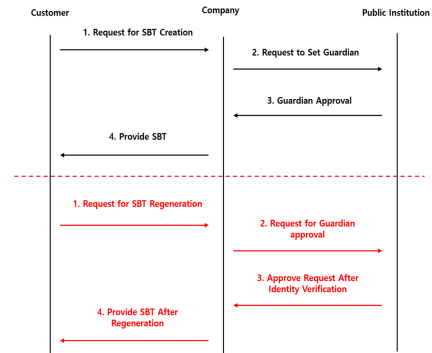


Fig. 4. Traditional Guardian System

축하고 있으며, 이를 위한 보안 방법으로 “고객 중심 가디언” 시스템을 고려하고 있다. 스타트업의 환경에서는 공공기관과의 연계가 불필요한 자율적인 데이터 복구 방식이 비용 절감과 시간 절약에 큰 이점을 제공한다는 장점이 있다. 이러한 차이는 Table.1에 정리하였다.

“고객 중심 가디언” 시스템은 1명의 고객의 가디언으로 2명의 관리자와 3명의 다른 고객, 총 5명의 가디언을 설정하는 방식이다. 기존의 고객 3명이 다음 고객 3명의 가디언으로 설정되고, 다음 고객 3명은 또 다음 고객 3명의 가디언으로 설정하는 방식으로 계속해서 고객이 고객의 가디언으로 설정된다. 본 방식은 블록체인의 기본 원칙인 탈중앙화에 부합하며 새로운 고객이 들어와도 연속적으로 가디언을 설정할 수 있다는 점에서 유연성과 확장성을 갖추고 있다.

“고객 중심 가디언” 시스템은 새로운 고객이 추가

Table 1. Comparison with the traditional guardian system

Feature	Traditional Guardian	Customer-Centric Guardian
Dependence	Relies on centralized public institutions	Relies on a decentralized customer network
Trust Model	Depends on the trustworthiness of public institutions	Depends on mutual trust among customers
Security	Relies on the security of public institutions	Enhanced security through multiple customer guardians
Cost	Incurs	No additional costs
Decentralization	Only partially possible	Fully decentralized implementation possible
Recovery Mechanism	Requires approval from public institutions	Allows recovery through the approval of multiple customers
Response Time	Can be delayed by the procedures of public institutions	Fast response through quick customer interactions

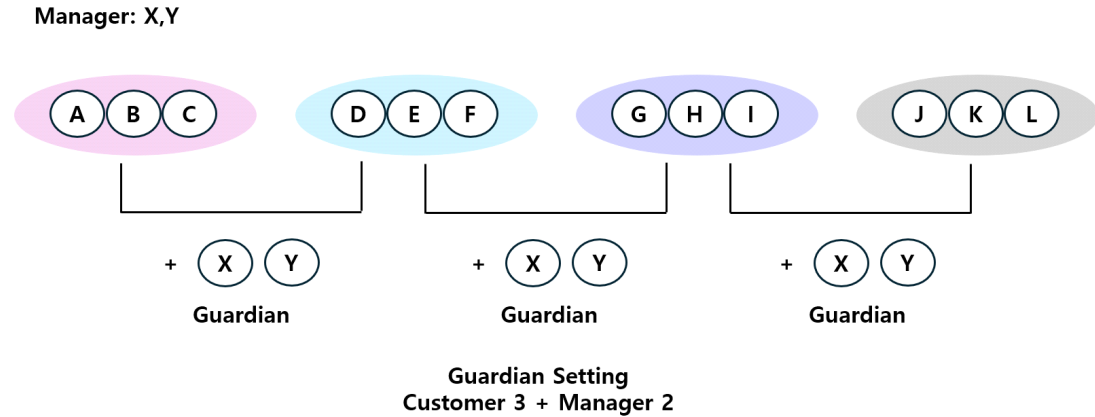


Fig. 5. Customer-Centric Guardian System

될 때마다 이전 고객들이 새로운 고객의 가디언 역할을 맡게 된다. 이를 통해 네트워크 내에서 모든 고객이 서로의 가디언으로 연결되며, 중앙화된 기관의 개입 없이도 자율적으로 시스템의 신뢰성을 유지할 수 있다. 예를 들어, 새로운 고객 D가 시스템에 가입하면, 기존 고객 A, B, C가 고객 D의 가디언이 된다. 이후 고객 D는 다음에 가입하는 고객 G, H, I의 가디언으로 설정된다. 초기 고객의 경우에는 매니저 3명이 가디언으로 설정된다.

4.2 고객 중심 가디언 실험

4.2.1 실험 환경 설명

실험은 Ethereum Virtual Machine을 활용한 시뮬레이션 환경에서 수행하고, 스마트 계약의 구현

에는 Solidity 언어를 사용한다. 개발 환경은 Remix IDE를 이용하였으며, 테스트는 Linea Sepolia를 활용하여 로컬 블록체인 네트워크에서 진행한다.

4.2.2 가디언 설정 결과

가디언 설정 결과는 스마트 계약의 다중서명 로직을 통해 확인되었으며, 모든 테스트 케이스는 예상대로 작동한다. 예를 들어, 고객 A1의 복구 요청 시, 가디언 Z1, M1, M2의 서명이 필요하며, 실제로 서명된 기록은 다음과 같이 스마트 계약의 로그를 통해 확인한다. 실험에 사용된 계좌는 Table.2와 같다.

4.2.3 함수별 예상 시나리오

requestRecovery 함수의 경우 고객이 계정을

Table 2. Account List For Experiment

Roll	Name	Account
Execution Manager	Z1	0x92A19C66448154955A24601a25f1E9E758e7a40d
Manager1	M1	0x5B38Da6a701c568545dCfcB03FcB875f56beddC4
Manager2	M2	0x072e560a4FcE2F8543A2977B79cEF5e806B816B9
Customer1	A1	0xAb8483F64d9C6d1EcF9b849Ae677dD3315835cb2
Customer2	A2	0x4B20993Bc481177ec7E8f571ceCaE8A9e22C02db
Customer3	A3	0x78731D3Ca6b7E34aC0F824c42a7cC18A495cabaB
Customer4	B1	0x617F2E2fD72FD9D5503197092aC168c91465E7f2
Customer5	B2	0x17F6AD8Ef982297579C203069C1DbfFE4348c372
Customer6	B3	0x5c6B0f7Bf3E7ce046039Bd8FABdfD3f9F5021678
Customer7	C1	0x03C6FcED478cBbC9a4FAB34eF9f40767739D1Ff7
Customer8	C2	0x1aE0EA34a72D944a8C7603FfB3eC30a6669E454C
Customer9	C3	0x0A098Eda01Ce92ff4A4CCb7A4ffFb5A43EBC70DC
Customer10	D1	0xCA35b7d915458EF540aDe6068dFe2F44E8fa733c

복구할 때 사용되는 함수로 고객이 아닌 계정이 복구 요청을 하거나 이미 복구 요청이 진행중인 상태에서 다시 요청을 할 경우 에러 메시지를 출력하도록 설계하였다. approveRecovery 함수의 경우 가디언이 고객의 복구 요청을 승인할 때 사용되는 함수로 고객이 복구 요청을 하지 않았을 때, 가디언이 아닌 계정이 승인을 요청했을 때, 이미 승인을 완료한 가디언이 중복 승인을 요청했을 때, 거절한 가디언이 승인을 시도할 때 각각의 에러 메시지를 출력하도록 하였다. rejectRecovery 함수는 매니저들이 모두 복구 요청을 거절할 경우 다른 가디언들과 상관없이 복구가 거절되도록 만드는 함수로 매니저만 거절할 수 있도록 설계하였다. 내용은 Table.3와 같다.

Case1은 매니저 2명과 첫 번째 고객이 승인했을 경우 바로 복구가 진행되는 상황이다. Case2는 매니저2 명이 승인을 하고 다음 고객 가디언 2명이 거절을 했을 경우에도 마지막 고객 가디언이 승인하면 복구가 진행되는 상황이다. Case3은 매니저 2명이 승인했으나, 고객 3명이 모두 거절하여 복구가 진행되지 않는 상황이다. Case4는 매니저 2명이 모두 거절하여 승인이 안되는 상황이다. 내용은 Table.4와 같다.

4.2.4 실험 결론

본 시뮬레이션 결과, 고객 중심 가디언 시스템을 활용한 SBT 복구 메커니즘이 안정적으로 작동하였으며, 과반수 가디언의 동의로 효율적인 복구가 가능함을 입증하였다. Case3에서 가디언의 다중 서명이 부족하여 복구가 거부되었고, Case4에서 매니저가 모두 거절하여 복구가 거부됨으로써 다중 서명 기반의 보안성을 유지한 채 효율적인 복구가 가능함을 확인하였다. 또한 Case1 및 Case2에서는 승인 절차가 효과적으로 작동하여 복구가 성공적으로 완료되었다. 블록체인 이벤트 로그를 통해 데이터의 무결성과 불변성을 확인할 수 있었고, 이러한 결과는 제안된 시스템이 실질적으로 사용될 수 있음을 입증하며, 향후 실제 환경에서의 확장 가능성을 제시한다.

4.3 예상 위험 시나리오 및 대응 방법

예상되는 위험 시나리오 및 대응 방법은 Fig.6과 같다. 우선 회사가 해킹을 당해 직원이자 매니저 2명의 비밀키가 해킹당한 경우 나머지 가디언인 고객 3명의 개인키가 안전하기 때문에 5명의 과반수인 3명의 개인키를 안전하게 지킬 수 있다. 반대로 고객

Table 3. Exceptional Case List

Function	Exceptional Case	Result
requestRecovery	A non-customer account requests recovery	"Caller is not a registered customer."
requestRecovery	A request is already in progress	"Recovery already requested."
requestRecovery	Normal recovery request	recoveryRequests[msg.sender] = true, RecoveryRequested
approveRecovery	No recovery request made by the customer	"No recovery requested by this customer."
approveRecovery	A non-guardian account requests approval	"Caller is not a guardian for this customer."
approveRecovery	A guardian who already approved makes a duplicate request	"Guardian has already approved."
approveRecovery	A guardian who rejected attempts to approve	"Guardian has already rejected."
approveRecovery	Normal approval	approvalCount++
rejectRecovery	A non-manager account attempts to reject	"Only managers can reject recovery."
rejectRecovery	A manager who already rejected makes a duplicate request	"Manager has already rejected."
rejectRecovery	Normal rejection	GuardianRejected or RecoveryRejected

Table 4. Experimental Case Results

Case	Customer	Guardians	Vote result	Event result
Case1	B1	M1	approve	approvalCount = 1
		M2	approve	approvalCount = 2
		A1	approve	SBTRecovered
		A2	-	-
		A3	-	-
Case2	C1	M1	approve	approvalCount = 1
		M2	approve	approvalCount = 2
		B1	reject	-
		B2	reject	-
		B3	approve	SBTRecovered
Case3	B1	M1	approve	approvalCount = 1
		M2	approve	approvalCount = 2
		A1	reject	-
		A2	reject	-
		A3	reject	SBT Not Recovered
Case4	B1	M1	reject	-

중1 명이 지갑을 분실하여 개인 키를 잊어버렸을 경우에도 나머지 고객 2명과 매니저 2명의 개인키가 안전하기 때문에 SBT 재생성에 문제가 없다.

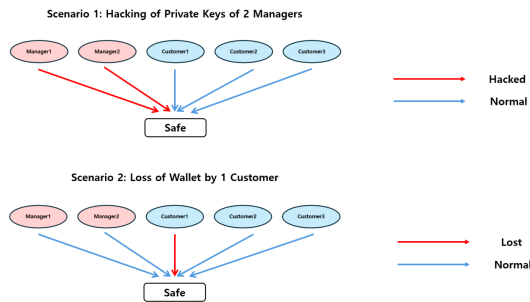


Fig. 6. Expected Risk Scenarios

4.4 추가적인 문제점 및 해결법

예상되는 문제점은 3가지가 있다. 첫 번째, 가디언으로 설정된 고객의 대답이 늦을 경우이다. 이러한 경우 위급한 상황에서 신속한 대처가 어렵기 때문에 24시간 이내에 대답이 없을 시 자동으로 대체 가디언 또는 매니저가 대신 승인 권한을 갖도록 스마트 계약에 규정할 수 있다. 이를 위해 타이머 기능을 스마트 계약에 내장하여, 응답 시간이 경과되면 자동으

로 대체 프로세스가 실행되도록 설정한다. 이를 위하여 guardianApproval 함수를 추가하였다.

두번째는 중간에 가디언으로 설정된 고객들이 탈퇴를 하는 경우이다. 이렇게 가디언 중 일부가 네트워크에서 이탈하는 상황을 대비해 자동 가디언 교체 알고리즘을 구현할 수 있다. 이 알고리즘은 가디언의 활동 여부를 모니터링하고, 특정 기간 동안 비활성 상태로 감지될 경우 시스템이 새로운 고객을 가디언으로 자동 선정한다. 이를 통해 가디언 네트워크의 연속력을 유지하며, 사용자가 이탈해도 시스템의 안정성을 확보할 수 있다. 스마트 계약을 통해 가디언의 비활성 기간을 추적하는 로직을 활용하여 코드를 구현한다. 이를 위하여 approveGuardian 함수를 추가하였다.

세번째는 해킹을 시도하려는 집단에서 악의적으로 가짜 고객들을 대거 투입하여 가디언 시스템 붕괴를 시도하는 경우이다. 이러한 경우 새롭게 투입되는 고객들이 추가로 들어오는 고객들의 가디언으로 설정되기 때문에 기존의 고객들의 정보를 안전하게 지킬 수 있지만, 시간에 걸쳐 조금씩 가짜 고객들이 들어올 경우 대응하기가 어려울 수 있다. 이러한 문제를 방지하기 위하여 새롭게 들어오는 고객들을 가디언으로 설정하기 전 다중 서명 기반 검증을 통하여 신원 확

인을 강화할 수 있다. 기존의 신뢰할 수 있는 가디언들이 새로 들어오는 고객의 신뢰성을 검증한 후 다수의 서명을 받아야만 가디언으로 등록되는 시스템을 통해 가짜 고객이 시스템에 진입하는 것을 방지할 수 있다. 이를 위하여 checkGuardianStatus Function 함수를 추가하였다.

4.5 후속 연구 방향

추가적인 해결이 필요한 문제들로는 고객이 신규 가디언으로 지정될 경우, 신뢰도를 검증하기 위한 다중서명 기반 인증 절차를 추가할 필요가 있다. 이를 위해 탈중앙화 신원 확인 시스템(DID) 방식을 적용하는 연구가 필요하다. 또한 본 연구에서는 초기 네트워크의 경우 매니저로만 가디언이 구성되지만, 초기 네트워크에 대한 더욱 구체적인 방안이 제시되어야 한다. 또한 실제 스타트업 환경에서 고객 중심 가디언 시스템을 적용하고, 실질적인 보안성과 신뢰성 평가를 수행해야 한다.

V. 보안 분석

5.1 STRIDE 분석

“고객 중심 가디언” 시스템을 중심으로 SBT의 보안 위협을 STRIDE[15] 분석법을 통해 분석하였고, 이에 대한 대응 방안은 다음과 같다.

5.1.1 Spoofing

악의적인 사용자가 가디언을 가장하여 SBT 복구 요청을 승인할 가능성이 있다. 이는 시스템 내의 신뢰할 수 없는 행위자가 다른 사용자를 속여 권한을 획득하려는 시도이다. 이에 대한 해결책은 다중서명 절차를 강화하는 것이다. 가디언 네트워크에서 SBT 복구 요청을 처리할 때, 최소 3명 이상의 가디언이 서명해야만 복구가 완료되도록 설정하고, 각 가디언의 서명은 이더리움 스마트 계약에 기록하여 다중서명 절차를 강화한다.

5.1.2 Tampering

가디언 시스템의 데이터를 불법적으로 조작하여 허위로 SBT를 복구하거나 데이터에 접근할 경우,

블록체인의 불변성 및 다중서명 기술을 사용하여 모든 거래와 복구 요청을 블록체인에 기록함으로써 변조가 불가능하도록 설계해야 한다. 또한, 모든 데이터 변경 요청은 다수의 가디언 승인 없이 수행할 수 없도록 하여 변조 시도를 방지한다.

5.1.3 Repudiation

가디언 또는 사용자가 SBT 복구 요청이나 승인 내역을 부인할 수 있다. 이는 이후에 발생하는 책임 소재 파악을 어렵게 하고, 시스템의 투명성을 위협할 가능성이 있다. 이에 대한 해결책은 블록체인에 모든 거래 및 승인 내역을 기록하여 투명성을 보장하고, 부인 방지 메커니즘을 강화하는 것이다. 각 가디언의 승인 내역은 변경 불가능한 형태로 블록체인에 저장되며, 모든 복구 과정은 명확하게 기록된다.

5.1.4 Information Disclosure

가디언 시스템을 통해 개인 식별 정보(PII), 블록체인의 거래 메타데이터, 데이터 접근 제어 정보 같은 민감한 개인정보가 노출될 가능성이 있으며, 이는 개인정보 보호법 위반 및 사용자의 프라이버시 침해로 이어질 수 있다. 이에 대한 해결책으로 데이터 암호화 및 접근 제어를 통해 민감한 정보를 보호해야 한다. 예를 들어, HTTPS를 통해 SBT 복구 요청 데이터를 암호화하고, TLS 핸드셰이크를 통해 대칭키를 안전하게 교환한다. 또한 AES 기반 암호화를 통해 복구 요청과 가디언 승인 데이터를 보호하며, TLS 인증서를 활용하여 서버 신뢰성을 보장한다.

5.1.5 Denial of Service

가디언 시스템에 대한 DDoS[16] 공격으로 SBT 복구 요청이 처리되지 않거나 지연될 수 있다. 이에 대한 해결책으로 시스템의 탄력성을 높이기 위하여 분산화된 네트워크 구조와 DDoS 방지 메커니즘을 도입한다. 또한 복구 요청 처리 지연을 방지하기 위해 스마트 계약에 타이머 기능을 내장하여, 일정 시간이 경과한 후 응답이 없는 가디언을 자동으로 제외하고 대체 가디언이 승인 절차에 참여할 수 있도록 설계한다.

5.1.6 Elevation of Privilege

권한이 없는 사용자가 가디언으로 승격되거나 관리자 권한을 획득하여 시스템을 악용할 수 있다. 이에 대한 해결책은 새로운 가디언을 등록하거나 권한을 변경할 때, 신뢰 점수 기반 평가와 기존 가디언 전원의 승인을 받도록 하는 엄격한 검증 절차를 적용하고 정기적인 권한 검토를 진행해야 한다. 이를 위하여 모든 과정을 블록체인에 저장하여 투명성을 강화하면, 권한 남용을 예방하고 시스템의 안정성을 유지할 수 있다.

VI. 결 론

이 연구에서는 SBT의 복구 메커니즘을 위한 “고객 중심 가디언” 시스템을 제안하여 기존 공공기관에 의존하는 가디언 시스템의 한계를 해결하고자 한다. 제안된 시스템은 블록체인 탈중앙화 특성을 활용하여 중앙 기관에 대한 의존도를 줄이고, 스타트업에 적합한 비용 절감 및 부담을 줄이는 효과를 기대할 수 있다. 제안된 “고객 중심 가디언” 시스템은 새로운 고객이 네트워크에 가입할 때마다 기존 고객들이 새로운 고객의 가디언 역할을 맡아 유연성과 확장성을 갖추고 있다. 또한 여러 고객이 가디언 역할을 분담하기 때문에 단일 실패 지점을 줄이고 전체 시스템의 보안을 강화한다.

예상되는 위험 시나리오 및 STRIDE 분석 방식을 통하여 “고객 중심 가디언” 시스템의 보안을 강화하였으며, 이 접근 방식은 스타트업에 원활하게 통합될 수 있는 장점을 제공한다. 하지만 향후 연구를 통하여 기존 가디언이었던 고객의 이탈이 발생했을 경우 보다 구체적으로 기존의 시스템을 유지하기 위한 방법을 제시해야 할 것으로 예상된다. 또한 가짜 고객들이 들어오게 되는 경우 다중 서명으로도 완전한 해결이 어렵기 때문에 이에 대한 후속 연구로 탈중앙화 신원 확인 시스템(DID)을 제안한다. 결론적으로, “고객 중심 가디언” 시스템은 중앙 기관의 개입 없이 블록체인 환경에서 신뢰할 수 있는 신원 확인 및 데이터 복구를 제공하는 유망한 대안으로, 스타트업에서 보안과 신뢰성을 강화할 수 있는 방안을 제시한다.

References

- [1] M. Kakebayashi and J. Beverley, “Soulbound Tokens (SBTs) Study Report Part 1: Building and Embracing a New Social Identity Layer?,” SSRN Electronic Journal, vol. 2023, no. 2, pp. 1-29, Feb. 2023.
- [2] J. Kim and S. Kim, “Implementation of SoulBound Token Using Economical and Efficient Decentralized File Storage Methods,” Journal of The Korea Institute of Information Security and Cryptology, vol. 34, no. 6, pp. 1345-1357, Dec. 2024.
- [3] Notion, “SBT Token Project,” Notion, <https://screeching-volcano-a43.notion.site/SBT-c247f21085364593a3b90ec5abdb0158>, accessed Mar. 24, 2025.
- [4] V. Buterin, Ethereum: A Next-Generation Smart Contract and Decentralized Application Platform, White Paper, pp. 1-36, Nov. 2014.
- [5] D. Trautwein, “Design and evaluation of IPFS: A storage layer for the decentralized web,” Proceedings of the ACM SIGCOMM 2022 Conference, Amsterdam, Netherlands, pp. 1-12, Aug. 2022.
- [6] A. Johnson and R. Smith, “Guardians in blockchain technology: A security analysis,” Blockchain Technology Review, vol. 5, no. 2, pp. 102-115, 2020.
- [7] I. Damgård, C. Orlandi, A. Takahashi, and M. Tibouchi, “Two-Round n-out-of-n and Multi-Signatures and Trapdoor Commitment from Lattices,” Advances in Cryptology - CRYPTO 2020, Lecture Notes in Computer Science, vol. 12171, pp. 502-532, Springer, Cham, 2020.
- [8] E. Rescorla, “The transport layer security (TLS) protocol version 1.3,” IETF RFC 8446, pp. 1-160, Aug. 2018.
- [9] C. Kaufman, P. Hoffman, Y. Nir, and

- P. Eronen, "Internet key exchange protocol version 2 (IKEv2)," RFC 7296, IETF, pp. 1 - 143, Oct. 2014.
- [10] K. E. Lever, M. Merabti, and K. Kifayat, "Single Points of Failure Within Systems-of-Systems," in Proceedings of the 2013 14th Annual PostGraduate Symposium on the Convergence of Telecommunications, Networking and Broadcasting (PGNet), Liverpool, UK, pp. 1 - 6, June 2013.
- [11] S. Huh et al., "Blockchain-based IoT device management," in Proceedings of the IEEE International Conference on IoT, pp. 123-130, Jun. 2017.
- [12] D. Minoli and B. Occhiogrosso, "Blockchain Mechanisms for IoT Security," Internet of Things, vol. 1-2, pp. 1 - 13, Aug. 2018.
- [13] Y. Zhang, L. Zhang, Q. Zhang, P. Zhang, X. Jia, and X. Chen, "DSBT: Research on Soulbound Token Mechanism Based on Consortium Blockchain and Decentralized Identity," in *Computational and Experimental Simulations in Engineering*, Springer, pp. 489 - 506, Dec. 2023.
- [14] V. Buterin, E. G. Weyl, and P. Ohlhauser, "Decentralized Society: Finding Web3's Soul," SSRN Electronic Journal, vol. 2022, no. 5, pp. 1 - 33, May. 2022.
- [15] A. Shostack, Threat Modeling: Designing for Security, Wiley, Indianapolis, IN, pp. 1 - 624, 2014.
- [16] J. Mirkovic and P. Reiher, "A Taxonomy of DDoS Attack and DDoS Defense Mechanisms in Modern Systems," ACM SIGCOMM Computer Communication Review, vol. 51, no. 2, pp. 45-61, Apr. 2021.

〈저자소개〉



김 재 현 (Jae-Hyun Kim) 학생회원
2021년 2월~현재: 건국대학교 응용통계학과 학사
2024년 2월~현재: 건국대학교 컴퓨터공학과 학사
〈관심분야〉 정보보호, 블록체인, 통계학, 인공지능



김 나 연 (Na-Yeon Kim) 학생회원
2022년 2월~현재: 건국대학교 응용통계학과 학사
〈관심분야〉 정보보호, 통계학, 인공지능



이 용 학 (Yong-Hak Lee) 정회원
2020년 2월: 건국대학교 응용통계학과 졸업
2022년 2월: 건국대학교 응용통계학과 석사 졸업
2022년 3월~현재: 건국대학교 응용통계학과 박사과정
〈관심분야〉 정보보호, 통계학, 인공지능



양 성 민 (Seong-Min Yang) 학생회원
2010년 2월: 건국대학교 수학교육학과 졸업
2020년 2월: 건국대학교 응용통계학과 석사 졸업
2020년 3월~현재: 건국대학교 응용통계학과 박사과정
〈관심분야〉 정보보호, 통계학, 인공지능



김 성 환 (Sung-Hwan Kim) 정회원
2007년 2월: 고려대학교 교육학 학사 졸업
2010년 2월: 고려대학교 통계학 석사 졸업
2015년 4월: 피츠버그 대학교 생물통계학 박사 졸업
2018년 3월~현재: 건국대학교 응용통계학과 부교수
〈관심분야〉 정보보호, 통계학, 인공지능